The Stuxnet attack on Iran

A Case Study in Cyber-Physical and Organizational Risk

Author(s): **Matteo Bregola (11095785)**

Bianca Denisa Gaga (11095777)

Dario Antonino Santo (10733108)

Professor: **Prof. Trucco Paolo, Prof. Maccarone Paolo**

Academic Year: 2024-2025

Contents

Contents **i**

1 Introduction **1**
1.1 Geopolitical Context 2
1.1.1 Considerations 3

2 Plant General Description **4**

3 Key Milestones in the Lifecycle of Stuxnet **6**

4 Fault Tree Analysis of Stuxnet **8**
4.1 Brief introduction on FTA 8
4.2 Fault Tree 8
4.3 Stuxnet Analysis 16
4.3.1 Version 1.0 16
4.3.2 Version 2.0 17
4.3.3 Version 2.1 18
4.3.4 Considerations 19

5 Behavioral Analysis **21**
5.1 Brief introduction on Behavioral Analysis 21
5.2 Behavioral Analysis Schema 21
5.3 In-Depth Analysis 22
5.3.1 Main Event 22
5.3.2 Organisational vulnerabilities 22
5.3.3 System factors pathway 22
5.3.4 Human factors pathway 24

6 Conclusions **26**

List of Figures **27**

Bibliography **28**

1 Introduction

Stuxnet has been one of the most significant and sophisticated cyber-security attacks in the history of cybersecurity, designed to sabotage the Iranian nuclear program. The malware is a meaningful example of hybrid attack, since it combined traditional cyber threats with physical consequences, showing that warfare has been evolving in the modern era. This kind of attack leverages the manipulation of industrial control systems in order to produce tangible and destructive outcomes, as demonstrated by Stuxnet's abilities to disrupt industrial processes. Furthermore, it accentuates the increasing interdependence between digital and physical systems, which raised significant concerns among the industries that depend on both for their operations[1].

The paper focuses on the analysis of Stuxnet, which has been a revolutionary event in the realm of cyber-physical security and the first documented instance of a cyber-weapon that caused physical damage to critical industrial infrastructures. Specifically, the target of the operation was the uranium enrichment process at the Iranian Natanz enrichment complex. Therefore, this incident has been a valuable case study for understanding the interaction between cybersecurity, industrial operations, and geopolitical dynamics.

Our research covers four primary objectives. Firstly, it examines the geopolitical and strategic significance of the Natanz facility, as well as the reasoning of the actors involved, in order to contextualize the attack. Secondly, it provides a technical description of the plant, focusing on the infrastructures that characterize the complex, including the SCADA systems and PLCs Siemens that were manipulated by Stuxnet. It proceeds with a Fault Tree Analysis that has been used to deconstruct the failures and vulnerabilities of the systems, which made the attack possible, and to identify some key suggestions for risk management strategies in similar industries. Finally, you can find a behavioral analysis[2] to highlight both human and organizational factors that contributed to the success of the attack.

This multidisciplinary approach offers a comprehensive understanding of Stuxnet. Examining both human and technological factors, our study sheds light on how complex it is to defend critical infrastructures from advanced cyber threats. In addition, it highlights how organizations must integrate technological defenses with organizational and behavioral risk management strategies.

[1] To have an overview on hybrid attacks we consulted the following paper: [6]
[2] Including the finding of insider actions, errors, and decision-making processes

1.1. Geopolitical Context

Understanding the geopolitical landscape is essential for identifying the threat actors involved in the accident (*Figure 1.1*). Iran's nuclear program began in 1957 with the Agreement for Cooperation Concerning Civil Uses of Atomic Energy [8], signed between Shah Mohammed Reza Pahlavi and the United States. Until 1979, the development of nuclear energy infrastructure and facilities progressed, supported by international collaboration. During this period, Iran signed the Treaty on the Non-Proliferation of Nuclear Weapons (NPT) [7], subjected itself to International Atomic Energy Agency (IAEA) inspections, and established the Atomic Energy Organization of Iran (AEOI). The geopolitical equilibrium shifted dramatically following two key events: the Iranian Revolution in 1979 and the subsequent Iran-Iraq War, which lasted until 1988. These happenings fostered hostile tensions with the United States and Israel due to several factors, including the anti-Western ideology of the newly established Islamic Republic, concerns over oil access and transportation, and fears of potential Soviet expansion. Furthermore, they spurred a domestic interest in developing nuclear weapons, partly in response to Saddam Hussein's nuclear ambitions during the conflict and Israel's existing nuclear arsenal. Between 1987 and the early 2000s, Iran resumed its nuclear program through agreements with various entities, including Pakistan (1987), China (1991), and Russia (1995). A turning point occurred in 2002 when the National Council of Resistance of Iran (NCRI) revealed the existence of a covert uranium enrichment facility in Natanz, raising international concerns about the true purpose of Iran's nuclear activities. Although Iran claimed the facility was intended for power generation, subsequent IAEA inspections reported the country's noncompliance with its NPT safeguards agreement. In 2006, the United Nations Security Council demanded the suspension of nuclear enrichment activities, a demand Iran refused, leading to the imposition of multiple sanctions. Several reports from the IAEA, between 2007 and 2009, highlighted Iran's steady progress in nuclear enrichment, alongside a lack of transparency that obstructed the agency's ability to verify the peaceful nature of Iran's nuclear activities [1]. Meanwhile, Israel remained highly focused on Iran's nuclear program, with reports suggesting that Mossad was responsible for the assassination of several Iranian nuclear scientists. Israel also reportedly sought U.S. approval to use Iraqi airspace for a potential strike on Iran's Natanz facility, although the United States denied permission. In response, the U.S. government, particularly the National Security Agency (NSA) and Central Intelligence Agency (CIA), began planning attack operations, and by 2009, covert cyber operations against Iran were reportedly authorized. After 2009, the IAEA focused on monitoring Iran's nuclear program, highlighting concerns about its past nuclear weaponization activities. While no evidence of ongoing nuclear weapons development was found, there were significant tensions, especially between 2009 and 2013, as Iran continued uranium enrichment and was accused of not fully cooperating with IAEA investigations into military-related aspects of its program. In 2015, the IAEA closed its investigation into Iran's past nuclear activities, confirming that Iran had addressed most of the agency's concerns. This

paved the way for the Joint Comprehensive Plan of Action (JCPOA), under which Iran agreed to limit its nuclear activities in exchange for sanctions relief. The IAEA continued to verify Iran's compliance with the deal, confirming reductions in enriched uranium and increased inspections.

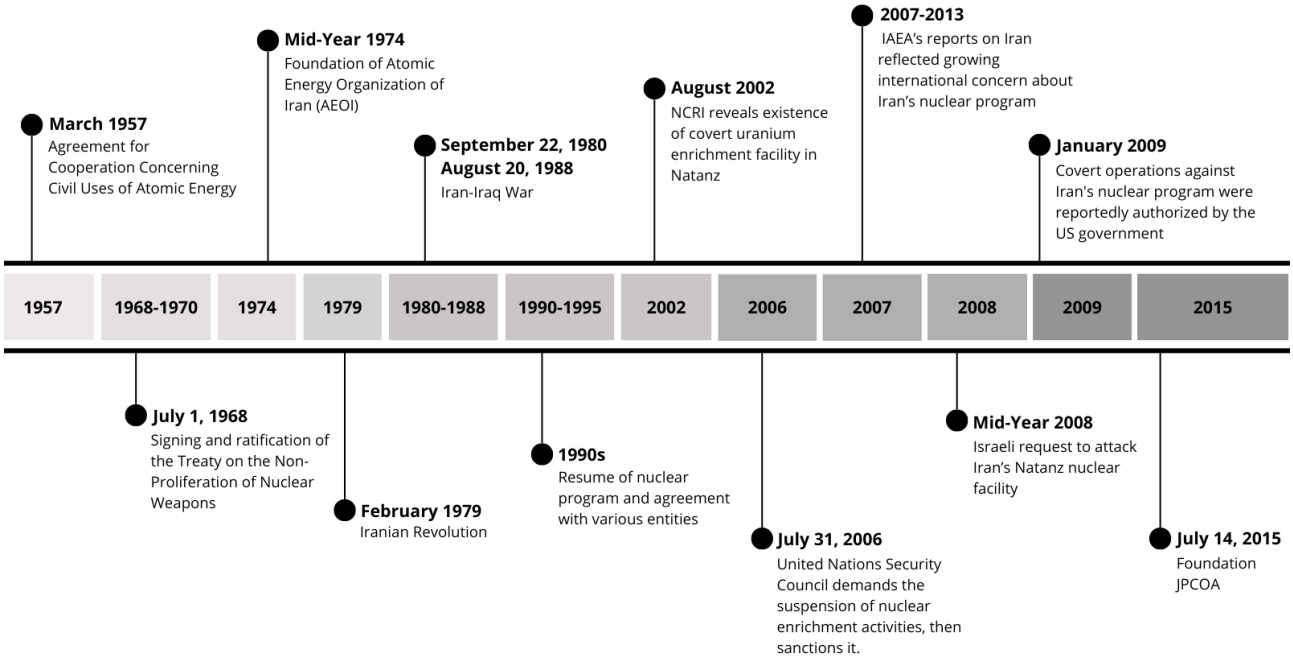

Figure 1.1: Geopolitical Timeline

1.1.1. Considerations

The preceding paragraph highlights the complexity of Iran's efforts to develop uranium-related facilities, involving numerous actors. The period following the 2002 revelations, especially during the era of International Atomic Energy Agency (IAEA) reports, subjected Iran's nuclear program to intense international scrutiny. This heightened attention elevated the strategic importance of these facilities, making them high-value targets for Western nations, particularly the United States and Israel, which viewed Iran's nuclear ambitions as a critical threat requiring neutralization. The Natanz facility, once an obscure and secretive site, rapidly became one of the most well-known and widely discussed locations, targeted by entities with vastly superior capabilities and resources.

2 | Plant General Description

Natanz nuclear facility, also known as Natanz Enrichment Complex, is located around 300 km south from Tehran, the capital city of Iran. The infrastructure covers a really vast area of approximately 100.000 square meters, of which a significant part is established underground, in order to protect it from any possible aircraft attacks, thanks to cement and soil layers. Taking into consideration the whole Iranian nuclear programme, Natanz is the key site for it. In particular, the main activity of the facility is uranium enrichment, along with R&D, and manufacturing and assembly of centrifuges useful for its principal function. Natanz's structure consists of six above ground buildings and three underground buildings, which are designed to accommodate more than 50.000 IR-1 and IR-2 centrifuges for the uranium enrichment, more specifically they work to separate uranium-235 and uranium-238[1] through a high speed process, due to the fact that U-235 needs to be separate from any other part of the mineral, since it's the only suitable part for nuclear fuel or weapons. The two models of centrifuges employed at Natanz differ as follows: IR-1 models have been used since the pakistan P-1 project, still used even if they have been declared obsolete, while IR-2 models offer a higher efficiency and capacity of enrichment.

The operational process is composed of three main elements, which are feed, product and tails. Specifically, starting from the feed, the system receives raw UF6 gas[2], which is being introduced in the centrifuges for the isotope separation process. Then, the gas is fed into a cascade of centrifuges, which are arranged into specific configurations in order to increase progressively the level of the enrichment. The product stream, coming from the separation process, contains a high level of U-235, which is then collected in sealed tanks for transport and the final use. The remaining fractions, also known as tails, have a lower concentration of U-235 (it's a very low percentage, generally lower than 0.3%): this part is recycled or removed in accordance with environmental regulations. Another important detail that should be highlighted about the centrifuges is the fact that they are grouped into cascades, which, in turn, are sub-groups of centrifuges categorized by the function they have in the process [3].

The entire plant is managed by a SCADA system, an acronym for Supervisory Control and Data Acquisition. SCADA refers to a class of software applications designed to oversee and control industrial processes. It enables the real-time collection of data from remote locations to

[1] Chemically they are identical, but they differ in the physical properties, in particular in their mass. Indeed, U-235 contains 92 protons and 143 neutrons, which lead to a 235 units mass, while U-238 has the same number of protons but 146 neutrons, which lead to a 238 units mass. So, the difference in mass of the two different types of uranium makes it possible to increase ("enrich") the percentage of U-235

[2] Known as uranium hexafluoride

[3] To better clarify the concept: each cascade may be composed of hundreds of centrifuges, which are, in turn, organized into numerous clusters

monitor equipment and operational conditions effectively. However, the SCADA system does not directly interact with plant components, such as valves and sensors; instead, it communicates through programmable logic controllers (PLCs). At the Natanz facility, two primary models of controllers are in use: the Siemens S7-400 and S7-315. In addition to the physical protection we were quoting above, Natanz is isolated from the external network thanks to an air gap system, which aims at securing SCADA systems from possible informatic attacks. Moreover, the International Atomic Energy Agency regularly checks the facility to be sure that international agreements are observed.[4]

[4]The plant description has been redacted by analyzing these papers [2, 3, 5, 10]

3 | Key Milestones in the Lifecycle of Stuxnet

This chapter[1] highlights the key milestones of Stuxnet from its development to its decline. It helps trace its lifecycle from when its C&C server first registered in 2008 to when it self-destructed in 2012, and shows how it became a landmark cyber weapon (*Figure 3.1*).

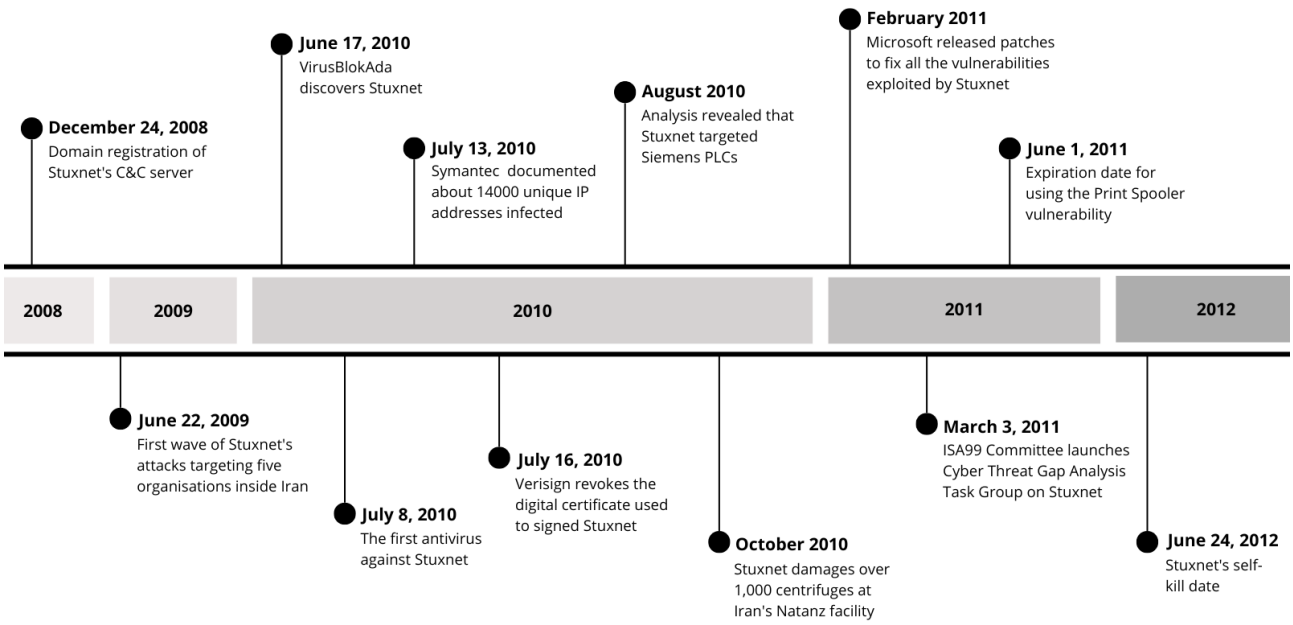

Figure 3.1: Key Milestones Timeline

A short description of the events:

- 24 December 2008: The domain for Stuxnet's command-and-control (C&C) server[2] was registered, indicating the end of its development phase and the readiness for deployment.
- 22 June 2009: First wave of Stuxnet's attacks targeting five organizations inside Iran. The Natanz plant had an isolated network, so Stuxnet could not penetrate directly. So they

[1] We have built a timeline of the main events of Stuxnet based on the reconstructions of the papers [4] and [5].

[2] A centralized computer system used by attackers to remotely manage and control malware-infected devices.

decided to infect five surrounding companies that they knew would get inside Natanz. Within a year, these attacks resulted in approximately 12,000 infections.

- 17 June 2010: Stuxnet was first discovered by the Belarusian security company VirusBlokAda, following unexplained system reboots on the computers of a customer in Iran. The malware spread through USB drives exploiting the vulnerability .LNK [3] on a zero-day basis.
- 8 July 2010: Microsoft Security Essentials became the first antivirus software to detect a specific version of Stuxnet, identifying it as TrojanDropper:Win32.Stuxnet.A
- 13 July 2010: Symantec[4] documented the worm's reach, discovering approximately 14,000 unique infected IP addresses within 72 hours of its analysis.
- 16 July 2010: Verisign revoked the compromised Realtek Semiconductor digital certificate [5] used to sign Stuxnet's rootkit files[6].
- By August 2010: Analysis revealed that Stuxnet specifically targeted Siemens industrial control systems (PLCs), used in manufacturing and utility firms.
- October 2010: Reports confirmed Stuxnet had caused damage to more than 1,000 centrifuges at Iran's Natanz nuclear enrichment facility. According to China's state news agency Xinhua, about 1000 enterprises and more than six million individual computers have been infected by Stuxnet.
- February 2011: Microsoft released patches to fix all the vulnerabilities exploited by Stuxnet, closing the zero-day exploits used by the malware.
- 3 March 2011: The ISA99 committee launched a cyber threat analysis task group specifically focused on Stuxnet.
- 01 June 2011: The expiration date for the use of the Print Spooler vulnerability (MS10-061)[7], exploited by Stuxnet.
- 24 June 2012: Stuxnet's built-in self-termination feature activated, causing the malware to cease operations and effectively auto-destruct.

[3] A security flaw in Windows shortcut files (with the ĖNK extension) that attackers can exploit to execute malicious code.

[4] The actual Norton.

[5] An electronic credential issued by a trusted authority to verify the authenticity of software or its publisher, ensuring it has not been tampered with.

[6] Malicious programs designed to hide the malware's presence and activity, ensuring it remained undetected on the infected systems.

[7] A critical security flaw in the Windows Print Spooler service.

4 | Fault Tree Analysis of Stuxnet

4.1. Brief introduction on FTA

Fault Tree Analysis (FTA) is a highly used method in system safety and reliability engineering. It was designed to identify and analyze the causes of critical failures in complex systems. It focuses on a specific undesirable event, known as the Top Event (TE), and it systematically traces its potential root causes, through a graphical representation, using logic gates and Boolean algebra.

We underline that FTA is a focused approach on particular system failure modes and their root causes, rather than a model that can be used for any system failure or potential causes. This focused methodology is particularly effective in addressing failures associated with critical system hazards, allowing analysts to identify and prioritize the most impactful risks.

Thanks to this kind of analysis, we can get a deeper understanding of system vulnerabilities and interdependencies. Therefore, FTA is an invaluable tool to evaluate and mitigate risks in safety-critical domains, including infrastructure protection, industrial operations, and cybersecurity.

4.2. Fault Tree

In this section[1], we present a fault tree (*Figure 4.1*) that will later be used to explore how each version of Stuxnet impacted the Natanz plant's systems. It is important to note that our study does not aim to cover every possible scenario in which the top event (widespread damage to the centrifuges) could occur[2]. This is because fault trees are designed to model specific failure modes and their contributing factors, rather than account for every potential failure or cause within a system. Furthermore, we aim to leverage the fault tree as a tool to examine the hybrid risks associated with this specific incident within the plant. Additionally, covering all potential causes of the top event in such a complex facility is not feasible, especially given the absence of complete official disclosure regarding the plant's structure.

[1]THis analysis is mainly based on the work of Ralph Langner [5], whose research is widely regarded as one of the most accurate studies on the case.

[2]This reasoning also applies to the other elements of the tree. For example, a Siemens S7-417 controller failure is represented as a leaf, even though there are multiple possible reasons behind its fault (e.g., software bugs, faulty Profibus connections, power outages, malware, etc.)

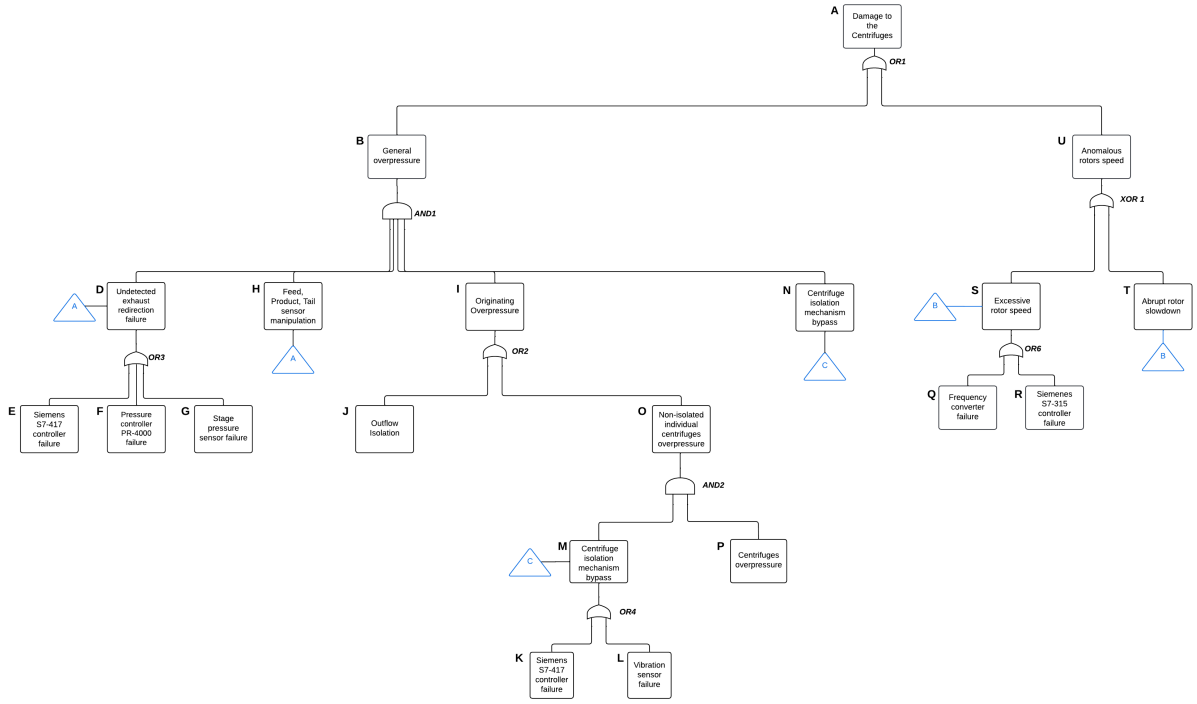

Figure 4.1: Fault Tree

A| Damage to the Centrifuges

Description: The centrifuges are damaged. In our analysis this can be caused by two elements: a general overpressure of the system OR an anomalous rotor speed.

Failure Consequences: The centrifuges are the most critical and sensitive components of the enrichment plant. Damage to one or more centrifuges significantly slows the enrichment process, as they must be replaced to restore full functionality.

B| General Overpressure

Description: The Cascade Protection System (CPS) fails and the system experiences a general overpressure. The CPS is a fault-tolerance mechanism that operates at both the centrifuge level and within each enrichment stage in order to grant a stable pressure. More specifically, it can isolate a specific failing centrifuge (*see Node N*) or an entire stage *(see Node D)*[3]. In order to fail it require ALL four child nodes to occur simultaneously. Excluding any one of these elements would prevent the consequence. Let us analyze why:

- Removing "Undetected exhaust redirection failure" [Node D]: Without altering the stage exhaust valve mechanism, an available outflow would persist, effectively pre-

[3]Therefore, it offers two "levels" of protection both of which must be bypassed to cause a general pressure buildup.

venting pressure buildup and related issues.

- Removing "Undetected centrifuge isolation malfunction" [Node N]: Without manipulating the centrifuge isolation mechanism, a general overpressure would activate it, causing all centrifuges to be isolated independently.
- Removing "Feed, Product, Tail Sensor Manipulation" [Node H]: Without this manipulation, the system would eventually detect an anomalous relationship between feed, product, and tail flows, triggering an alert.
- Removing "Originating Overpressure": There is the need of an originating element that cause the general overpressure.

Failure Consequences: Prolonged overpressure can damage the centrifuges and lead to unrepairable mechanical failure. Excessive pressure may result in catastrophic failure, causing the release of UF6 gas.

D| Undetected exhaust redirection failure

Description: Each enrichment stage is equipped with a safety mechanism[4] that allows the flow from the stage's centrifuges to be redirected to a containment dump via a designated waste pipe. This mechanism is activated by opening a valve when the stage pressure sensor detects anomalous values and sends them to the controller. The process is overseen by an operator responsible for sending the signal to activate the valve. This node represents a failure of the safety mechanism that goes undetected due to the occurrence of ANY one of its child elements.

Failure Consequences: If the stage flow redirection fails during a pressure buildup, it can result in significant system instability due to increased pressure, especially if the system is not shut down promptly.

Note: The exhaust system can dysfunction for other reasons beyond the one mentioned. For example, a valve can have a mechanical fail or the operator could forget to activate it. However, these two elements would be easily detectable by the operators thereby making the attack not effective (or the failure manageable).

E| Siemens S7-417 controller failure

Description: The Siemens S7-417 controller, which manages the opening of the exhaust valve by communicating with the PR-4000 controller, either misconfigures, fails to read the input from the other controller, or reads it incorrectly.

Failure Consequences: The controller manage various components within the implant. In

[4] This is the first of the two fault-tolerance mechanism implemented by the CPS.

the context of this specific sub-tree, the controller failure leads to the non-opening of the stage's emergency exhaust valve.

Note 1: This component and the one labeled with K are related to the same physical element but they focus on different manipulation that lead to different consequences.
Note 2: We consider the controller as a singular entity for simplicity, although the system actually includes multiple controllers, likely with some redundancy. The redundancy, along with the number of controllers and their interconnections, influences the likelihood of this event occurring.
Note 3: For this node, as well as Nodes F and G, we assume that the incorrect measurement detects a stage pressure lower than the actual pressure.

F| Pressure controller PR-4000 failure

Description: Each enrichment stage in the system is equipped with a dedicated pressure controller, specifically a MKS PR-4000. These controllers are the interface between the physical devices (sensor and valve) with the controllers. This node describe an erroneous reading or conversion of analog signal coming from the pressure transducer.

Failure Consequences: A malfunction in the controller can lead to consequences similar to those described in node E.

G| Stage pressure sensor failure

Description: Each enrichment stage in the system is equipped with a dedicated pressure sensor. The analog signal from these sensors is utilized by corresponding pressure controllers to regulate the exhaust valve operation. This node describes an erroneous measurement of the pressure.

Failure Consequences: A malfunction in the sensor can lead to consequences similar to those described in node E.

H| Feed, Product, Tail sensor manipulation

Description: Feed, product, and tails headers have dedicated pressure sensors[5]. These values are essential to have an estimate of the system's efficiency and stability at each moment. This node describes a failure that causes the system to perceive product and tail values as consistent with the feed, even though the actual levels are significantly lower or even zero.

Failure Consequences: Faults in this sensor can result in various outcomes. For instance,

[5]The feed pipe likely includes an additional differential pressure sensor used as a flow meter. If present, this component would also need to be manipulated.

if the product and tail sensors report measurements higher than the actual values, it could result in an undetected pressure buildup. This occurs because the system might erroneously compensate by increasing the gas input to match the perceived outflow. Similarly, an under-measurement of the feed flow might prompt the system to introduce more gas into the system, further compounding the issue.

Note: The subtree originating from this component is not represented directly in the figure shown but uses the placeholder "A" to avoid repetition. In fact, the events that can cause this element are the same of the component "D" (beside the fact that for this one the pressure sensor is the product line one and not the stage).

I| Originating Overpressure

Description: This component describes a generic failure that cause a pressure in one stage or in a set of centrifuges that needs to be handled by the CPS. In our analysis, we identified that this "initial" pressure buildup can result either from outflow isolation (which directly affects multiple stages) OR from the non-isolation of faulty centrifuges (which creates a cascade effect).

Failure Consequences: The overpressure needs to be handled by the CPS in order to avoid that the "local" pressure buildup affects all the system.

J| Outflow Isolation

Description: The isolation valves for the first two and the last two enrichment stages are closed, effectively blocking the product and tail outflows of process gas for each affected cascade.

Failure Consequences: Blocking the outflow of processed gas while maintaining input from the feed significantly compromises system stability by causing overpressure.

Note: Insufficient information is available to determine how this event occurred. It is likely that both the pressure sensor and the valve were targeted by manipulating the pressure controllers through the Siemens controllers.

O| Non-isolated individual centrifuges overpressure

Description: The centrifuges have an isolation mechanism that permits to isolate them from its stage. The centrifuge is isolated by closing a valve which is activated by the Siemens S-417 controller based on the measurement of a sensor. This component describes the event in which one or some centrifuges experience overpressure AND the isolation mechanism fails without being noticed.

Failure Consequences: The undetected failure of the isolation mechanism of single centrifuges that experience a pressure buildup can create cascading failures that spread in the plant.

M| Centrifuge isolation mechanism bypass

Description: The centrifuges have an isolation mechanism that permits to isolate them from its stage[6]. The centrifuge is isolated by closing a valve which is activated by the Siemens S7-417 controller based on the measurement of a sensor. This component describes the event in which the isolation mechanism fails without being detected.

Failure Consequences: If some centrifuge experience a pressure buildup the missed isolation can spread the failure in the system.

Note1: It is not completely clear if all the individual centrifuges have a pressure sensor (in addition to the vibration sensor), if they do then we should add another OR child to this node (with a description similar to the one for the vibration sensor).
Note2: The isolation system can dysfunction for other reasons beyond the one represented by the children of this node. For example, the isolation valve can have a mechanical fail. However this would be easily detectable by the operators.

K| Siemens S7-417 controller failure

Description: The Siemens S7-417 controllers manage various components within the implant.In the context of this specific subtree, we focus on their failure to control the isolation valves connected to them via the Profibus network.

Failure Consequences: Erroneous functioning of the Siemens controller can result in a failure to activate the isolation valves when necessary.

L| Vibration Sensor Failure

Description: A sensor is attached to each centrifuge to measure the vibration produced by the process.

Failure Consequences: Incorrect vibration measurements can result in undetected abnormal behavior in the centrifuge, such as excessive speed or pressure. These conditions would typically cause increased mechanical stress, which could be reflected in the vibration readings but may go unnoticed if the sensor malfunctions or is inaccurate.

[6]This is the second fault-tolerance mechanism implemented by the CPS.

P| Centrifuges Overpressure

Description: The centrifuges experience overpressure caused by individual faults. These overpressure events can be triggered by various factors, such as mechanical imperfections in the rotor, misconfigurations of the rotation speed, and other potential issues.

Failure Consequences: The centrifuges needs to be isolated by the CPS in order to avoid cascading effects.

N| Centrifuge Isolation mechanism bypass

Description: *See description of Node M*

Failure Consequences: If the system experiences an overpressure and the centrifuge isolation mechanism fails, it loses one of its two fault-tolerance mechanisms.

Note: This node may seem like a "repetition" of Node M; however, they serve two distinct roles within the fault tree. The originating overpressure can result from two scenarios:

1. *Outflow isolation.*
2. *Failure to isolate individual faulty centrifuges.*

For the first scenario to cause a general overpressure, both isolation mechanisms at the stage level (Node D) and at the centrifuge level must fail. This is why Node N is required at this level of the fault tree.
The same applies to the second scenario. If the originating overpressure stems from the failure to isolate some centrifuges (Node M), the isolation mechanism of other centrifuges (Node N) must also be bypassed to generate a general overpressure; otherwise, only the initial overpressure would occur without escalating further.

U| Anomalous rotors speed

Description: The Centrifuge Drive System (CDS) fails and the centrifuges are brought to an abnormal operational speed.

Failure Consequences: The rotational speed of the centrifuges is a highly sensitive parameter. Both an abrupt decrease or an increase in speed can damage the centrifuges and the system as a whole.

S| Excessive rotor speed

Description: The centrifuges experience an anomalous high speed.

Failure Consequences: Excessive rotational speed can significantly reduce the lifespan of the

centrifuges, cause damage, or even result in complete destruction.

Q| Frequency converter failure

Description: Each centrifuge has its own motor coupled with a programmable frequency converter which establish the motor speed. The frequency converter are connected with the Siemens S7-315 controllers trough a Profibus Network. This component describes a failure in which the frequency converter mistakenly induces the motor to operate an higher speed than the intended one.

Failure Consequences: The wrong indication from the frequency converter induces the centrifuges operate at an excessive speed.

R| Siemens S7-315 controller failure

Description: the Siemens S7-315 controller handles the bahaviour od the frequency controller connected to the centrifuge motor. This component describes a failure of the controller that induces the frequency converter to operate the motor to an higher speed than the intended one.

Failure Consequences: The wrong indication of the controller indirectly forces the motor to operate to higher speeds.

T| Abrupt rotor slowdown

Description: The centrifuges undergo an abrupt slowdown before being restored to their normal operating speed.

Failure Consequences: An abrupt slowdown poses significant risks due to the fragility of the centrifuges. These devices typically operate at a constant speed and are not designed to withstand sudden changes. Such abrupt variations are highly likely to cause structural damage.

Note: This failure can be caused by the same events described in the subtree of S, as indicated by the placeholder B. The only difference is that, instead of increasing the failure of Q and R by speeding up the centrifuges, it slows them down.

4.3. Stuxnet Analysis

As anticipated in the previous section, we are going to leverage our fault tree to explain how the different versions of Stuxnet affected the system. Symantec [9] reports that the first version dates back to 22 June 2009 with a 3% of the total infections, the second one to 01 March 2010 with a 69% and the third one at 28% on 14 April 2010. The malware was introduced into the isolated network of the plant through USBs of infected contractors. It then spread within the network using several methods, exploiting sophisticated and previously unknown vulnerabilities.

4.3.1. Version 1.0

The first version of Stuxnet (*Figure 4.2*) targeted the Siemens S7-417 controllers (E,K). By taking control of this component, the attackers were able to intercept, record, and retransmit process input signals. This manipulation specifically allowed them to mask the values reported by the feed, product, and tail sensors (H), which monitor the gas balance entering and exiting the system, as well as the stage pressure sensor (which is used to activate the exhaust redirection mechanism) and the centrifuges' sensors.

As a result, the system received falsified data regarding its pressure status. Consequently, the exhaust redirection mechanism (D) and the centrifuge isolation mechanism (N) would not activate, as they continued to receive seemingly normal values.

Once the monitoring mechanisms were effectively "removed", the malware generated a source of overpressure (I) by isolating the gas outflow closing both the product and tail pipes (J). The combination of these four actions (sensor manipulation, gas outflow isolation, and bypass of the exhaust redirection and centrifuge isolation mechanisms) created a condition (B) where the plant was unstable and the SCADA system didn't recognize it.

More specifically, the system experienced dangerous and widespread overpressure. This condition was sustained for a specific duration and repeated multiple times, eventually causing severe damage to the centrifuges (A).

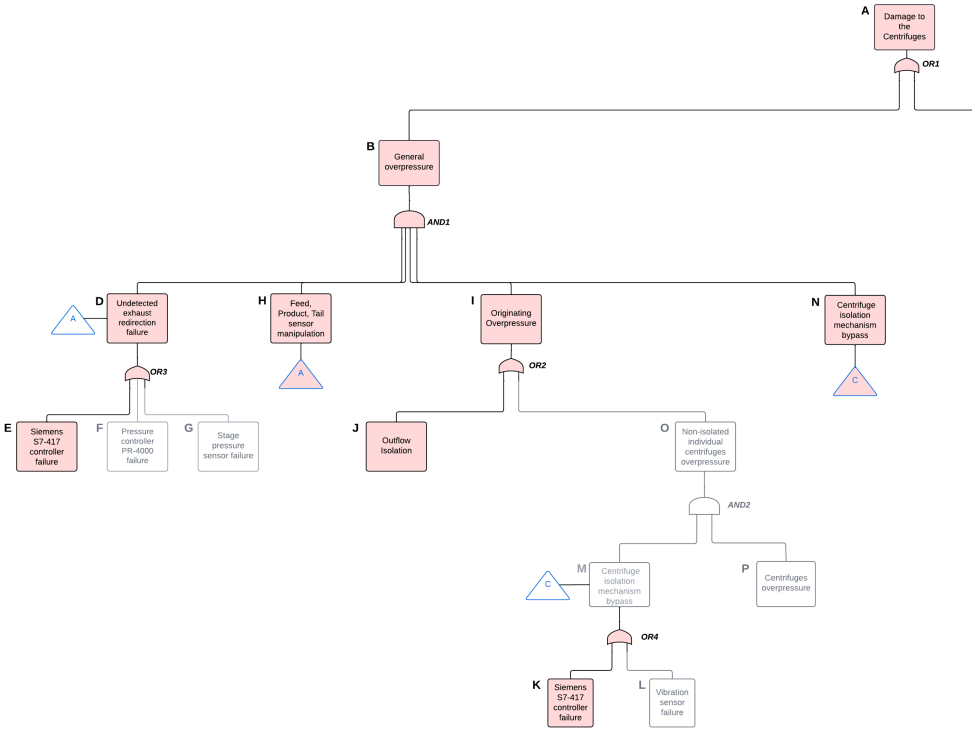

Figure 4.2: Stuxnet Version 1.0 fault tree branch

4.3.2. Version 2.0

The second version of the malware (*Figure 4.3*) targeted a different controller, the Siemens S7-315 (R). This controller manages the Centrifuge Drive System, which regulates the motor speed of each centrifuge. The malware manipulated the speed parameter sent by the controller to the frequency converter, increasing it by more than one-third.

A key distinction of this attack, compared to the previous version, is that the controller did not replicate the inputs from the frequency converters to the SCADA software. Instead, the control logic was directly modified to block the reading of these values, causing the system to continue displaying outdated data.

As a result of the parameter's modification, the infected controller increased the rotors speed (S). Any significant change to the centrifuge speed (U) can cause physical damage to the centrifuges (A), and this attack was no exception.

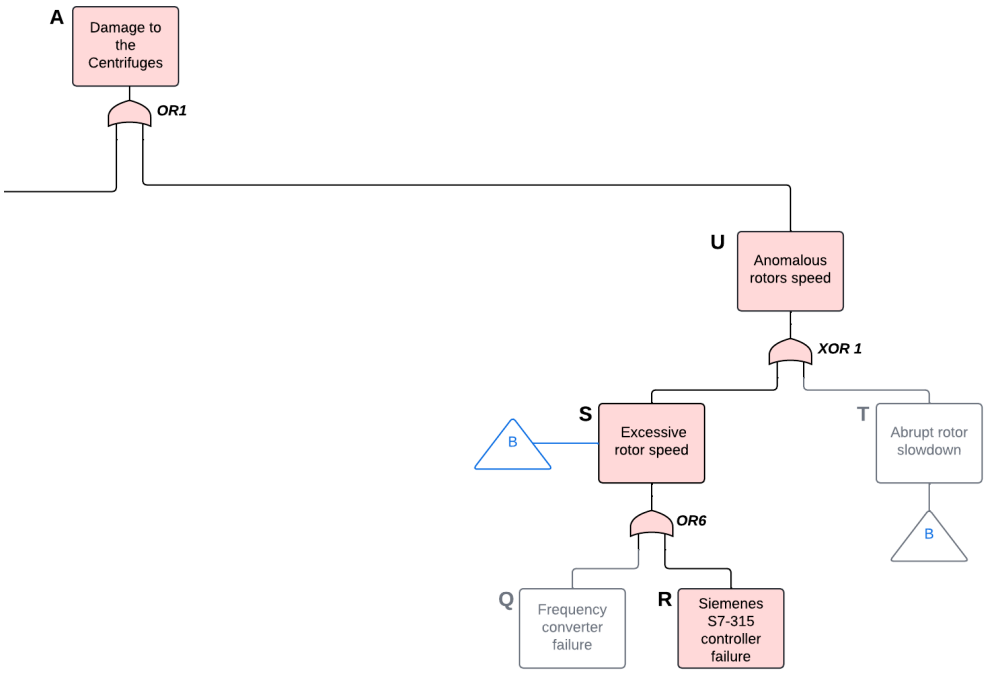

Figure 4.3: Stuxnet Version 2.0 fault tree branch

4.3.3. Version 2.1

The final version of Stuxnet (*Figure 4.4*) followed a pattern very similar to the previous one (*see Section 4.3.2*). The malware again targeted the Siemens S7-315 controllers. However, instead of increasing the centrifuge speed, this version abruptly slowed down the centrifuges (T), nearly bringing them to a stop, before quickly returning them to normal speed.

As in the previous case, the combination of abnormal rotor speeds (U) and abrupt changes caused significant stress, ultimately leading to damaging the centrifuges (A).

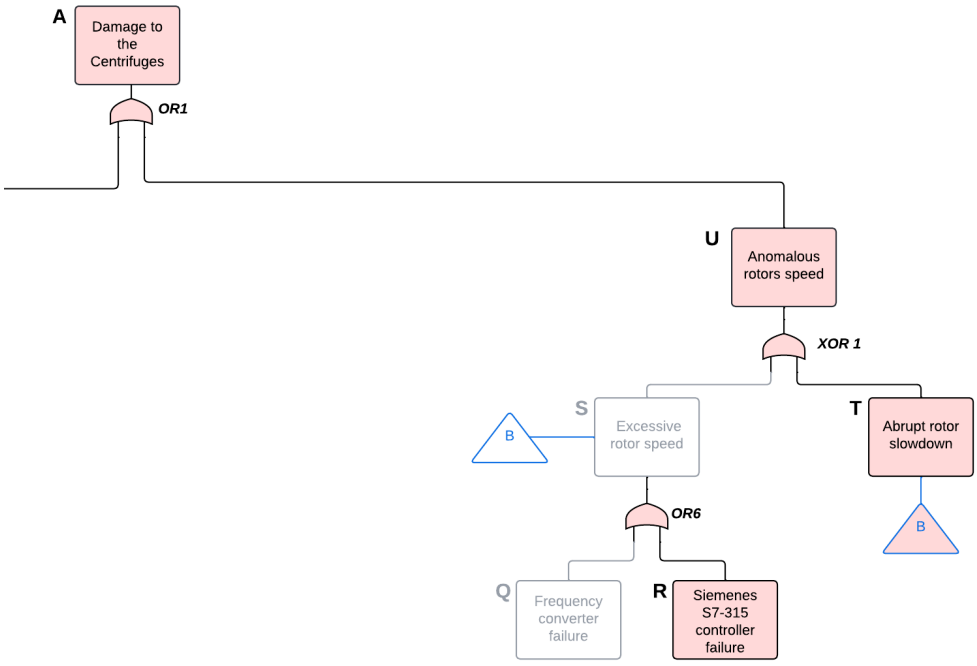

Figure 4.4: Stuxnet Version 2.1 fault tree branch

4.3.4. Considerations

All three versions of the malware operated periodically, targeting the system to cause damage without aiming for complete destruction. The objective was to reduce production output while remaining undetected. The analysis provided in this chapter indicates that this restrained behavior was deliberate, as each version had the potential to cause more abrupt disruptions (for example, instead of a slight increase in rotor speed, doubling it would have completely destroyed all the centrifuges simultaneously). Moreover, versions 2.0 and 2.1 could have combined their specific attack strategies with those of version 1.0, significantly amplifying the system's vulnerability. This suggests that the attackers prioritized persistence and stealth over immediate, large-scale damage.

Furthermore, without delving into the minimal cut set evaluation, it is evident that the PLC components (specifically the S7-416 and S7-315 versions) represent critical points of failure for the plant. Their compromise was a decisive factor in the critical incident analyzed, as it not only enabled the plant to operate in a damaging manner but also prevented detection and bypassed the existing fault-tolerance mechanisms.

This highlights a fundamental aspect of our analysis: security mechanisms designed for the physical world must be complemented by robust cybersecurity measures. While the plant implemented appropriate[7] risk management strategies to handle physical issues (such as centrifuge and stage isolation), these measures were controlled by the same technological components (Siemens controllers). As a result, they were rendered completely ineffective when the root cause of the problem was a cyberattack.

As a final consideration, we emphasize that the sophistication of the manipulation and its direct impact on the plant's procedures strongly suggest that the attackers had highly detailed knowledge of the facility, far exceeding the typical expertise of standard attackers.

[7] Actually, the fault-tolerance mechanisms were originally implemented more as a workaround for frequently recurring problems rather than as a dedicated system security mechanism. More details about this can be found in section 5.3.4.

5 Behavioral Analysis

5.1. Brief introduction on Behavioral Analysis

A behavioral analysis is a systematic approach used to study and understand human actions and decision-making processes within an organization in regard to errors and system failures. The purpose of such analysis is to determine the patterns of behavior, vulnerabilities, and interaction between humans and systems that result in an accident. It analyzes active failures, which are acts that can be directly linked to an accident, such as technical failures or faults, human errors and malicious attacks. Then it analyzes latent failures which include contributory factors that may lie dormant for days, weeks, or months until they contribute to the accident, such as organizational influences, supervision and preconditions.

5.2. Behavioral Analysis Schema

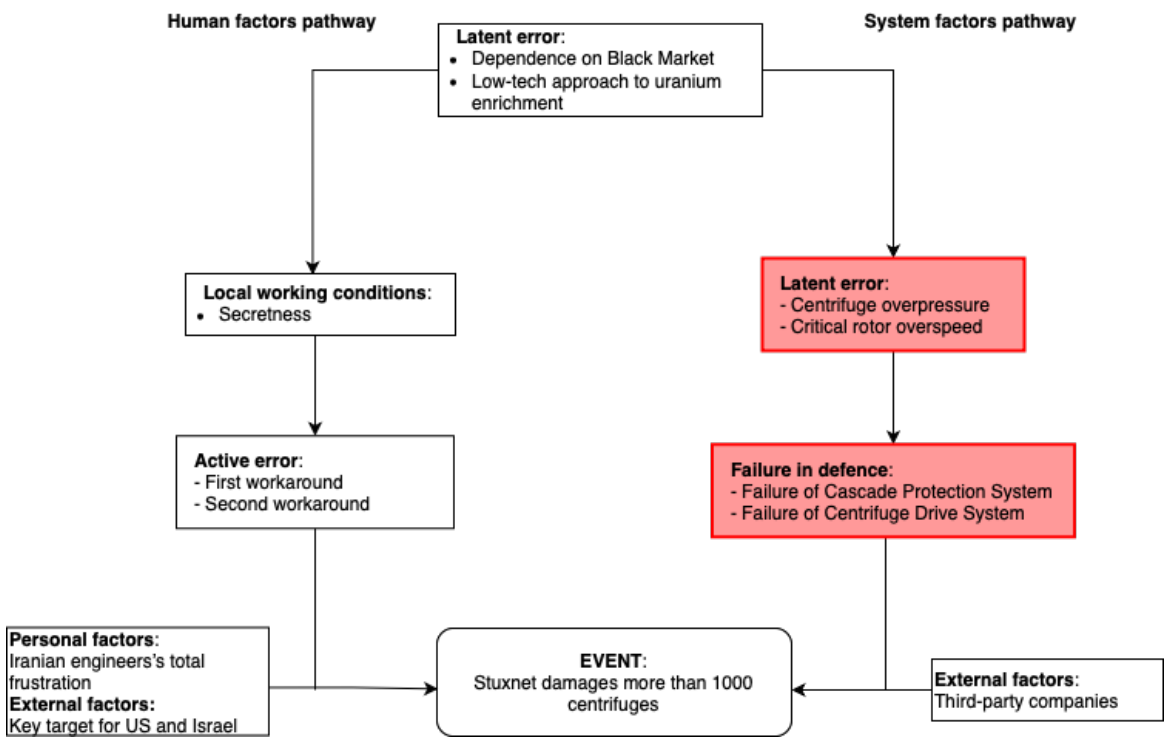

Figure 5.1: Behavioral Analysis Schema

5.3. In-Depth Analysis

5.3.1. Main Event

- **Stuxnet damages more than 1000 centrifuges**: as mentioned earlier in this paper, Stuxnet was intended to slow down Iran's nuclear program. Those who created Stuxnet knew that Natanz was the centerpiece of the nuclear program, and in the end the attack succeeded in damaging more than 1,000 centrifuges thus slowing down the Iranians for more than 2 years.

5.3.2. Organisational vulnerabilities

- **Dependence on black market**: the Natanz plant was entirely built with equipment from the black market in Pakistan. Pakistani nuclear physicist Abdul Khan negotiated with Iranian officials, and the transfer of the equipment took place between the 1980s and 1990s in Dubai. Having to depend on a black market is a vulnerability because you cannot create technology in-house, and this denotes a lack of expertise and a supply that is subject to disruption or external manipulation.
- **Low-Tech approach to uranium enrichment**: the backbone of the Iranian uranium enrichment effort is the IR-1 centrifuge, which dates back to a European project in the late 1960s/early 1970s. It is an obsolete design that Iran has never been able to operate reliably. IAEA (International Atomic Energy Agency) reports suggest that IR1 performed at less than half of what it could theoretically do. The main issues that we will explore in the following points were related to making the centrifuge rotors spin perfectly and reducing the centrifuge operating pressure to decrease the pressure on the rotor walls. The vulnerability here is the use of thousands of fragile centrifuges in a delicate industrial process that does not tolerate even small equipment snags.

5.3.3. System factors pathway

Latent error:

- **Centrifuge Overpressure**: the centrifuge overpressure problem represents a latent fault within the system, as it is a design vulnerability inherent in the enrichment process. The overpressure occurred when isolation valves and exhaust systems, intended to compensate for frequent centrifuge failures, were attacked by Stuxnet. This is a vulnerability: frequent failures are normalized, necessitating workarounds such as isolation valves and exhaust systems to maintain operations. This dependence on such mechanisms left an opening for potential attacks on the entire plant.
- **Critical Rotor Overspeed**: gas centrifuge rotors operate at supercritical speeds, where

even slight deviations can cause vibration, mechanical stress and catastrophic failure. This sensitivity makes rotor speed a crucial control variable that requires precise and reliable management. Although the system was capable of maintaining normal operating speeds (about 63,000 rpm), it lacked safeguards to prevent or respond to intentionally induced overspeed conditions. This vulnerability remained latent, as it would not manifest itself under standard operating conditions, but became a critical point of failure when exploited by Stuxnet.

Failure in defence:

- **Failure of Cascade Protection System**: the Cascade Protection System shows the status of each centrifuge within a cascade as either a green (running) or a grey dot (isolated). Immediately after infection the payload of this early Stuxnet variant takes over control completely. The attack code makes sure that when the attack is not activated, legitimate code has access to the signals; in fact it is replicating a function of the controller's operating system that would normally do this automatically but was disabled during infection. In what is known as a man-in-the-middle scenario in cyber security, the input and output signals are passed from the electrical peripherals to the legitimate program logic and vice versa by attack code that has positioned itself "in the middle".
- **Failure of Centrifuge Drive System**: the Centrifuge Drive System (CDS) controls rotor speeds and does so by using frequency converters to regulate the motor. Ensuring smooth acceleration and deceleration to avoid mechanical stress. During the attack sequence, legitimate control logic was suspended. The malware inserted its own commands, effectively taking full control of the centrifuge motors and isolating them from normal monitoring and security controls. Operating also in this case as man-in-the-middle.

External Factors:

- **Third-party companies**: as we mentioned in the plant description, the Natanz plant was protected by an air gap system that allowed the control systems to be isolated from external networks. But Natanz had 5 Iranian consulting companies under contract (water, electrical, etc.) that were targeted by the Stuxnet creators because they knew those companies would get inside the plant. So they decided to infect them, managing to penetrate inside Natanz.

5.3.4. Human factors pathway

Local working conditions:

- **Secretness**: Natanz is, from its inception, disguised as a desert irrigation system. As explained at length in the chapter "Geopolitical Context", the reasons why Iran had to conceal the resumption of its nuclear program go back to the 1979 Iranian revolution and the Iran-Iraq war that lasted until 1988. For the purpose of analyzing working conditions within the plant, we considered it crucial to include secrecy. This factor leads all workers within the plant to have to operate under even higher stress conditions, due in part to Mossad's killing of many of Iran's nuclear physicists.

Active error:

- **First workaround**: three fast-acting shut-off valves are installed for every centrifuge at the connectors of centrifuge piping and enrichment stage piping. By closing the valves, centrifuges that run into trouble – indicated by vibration – can be isolated from the stage piping. Isolated centrifuges are then run down and can be replaced by maintenance engineers while the process keeps running. But the isolation valves can turn into as much of a problem as a solution. When operating basically unreliable centrifuges, one will see shut-offs frequently, and maintenance may not have a chance to replace damaged centrifuges before the next one in the same enrichment stage gets isolated. Once that multiple centrifuges are shut off within the same stage, UF6[1] gas pressure will increase, which can and will lead to all kinds of problems.

- **Second workaround**: the second workaround is built on top of the first one. Basically it handles the pressure increase that occurs when multiple centrifuges in the same stage are isolated. In each enrichment stage, an unloader valve monitors the pressure via a sensor. If the pressure exceeds a certain level, the relief valve opens to release excess pressure into the exhaust system. This system, originally designed as a backup in emergencies, is used as a continuous control mechanism to maintain stable operating pressure.

Personal and external factors:

- **Iranian engineers's total frustation**: Stuxnet drove Iranian engineers crazy in the process, up to the point where they may ultimately end in total frustration about their capabilities to get a stolen plant design from the Seventies running, and to get value from their overkill digital protection system. If you compare Pakistani and Iranian uranium enrichment programs, you can see how Iran has achieved in 10 years the same progress that Pakistan has in 2 years. If Iran's engineers didn't look incompetent before, they certainly

[1] the most sensitive parameter in uranium enrichment using centrifuges

did during Operation Olympic Games (Stuxnet's alleged operational code name).

- **Key target for US and Israel**: the fact that Iran was a target not only of the United States and Israel but of most Western countries is a key factor to add to our analysis because it profoundly influenced Iranian strategies in pursuing its nuclear program. Iran, aware of international pressure and the risk of sabotage, sanctions, and targeted attacks, had to adopt independent solutions, develop redundant and decentralized systems, and resort to workarounds that could ensure the continuity of its program despite restrictions and interference.

6 | Conclusions

Stuxnet has been a crucial turning point in cybersecurity, geopolitical strategy, and industrial operations. This case study focuses attention on the relationship between physical, organizational, and cyber risks, establishing how failures in one domain can have a waterfall effect over the others, leading to important consequences. Besides revealing the vulnerabilities of industrial control systems, Stuxnet also introduced the concept of cyber-physical weapons and their importance in geopolitical entanglements.

The attack revealed significant vulnerabilities in the plant's existing security measures, which relied heavily on isolation from external networks and basic security software. However, Stuxnet demonstrated that even physically isolated systems can be compromised through unconventional attack vectors, such as infected USB drivers, and that security measures can be bypassed by exploiting unknown vulnerabilities. This highlights the need for a more robust and multi-layered security approach.

To mitigate similar risks in the future, a combination of technical, organizational, and strategic measures is essential. On the technical side, real-time anomaly detection systems, rigid protocols for isolated networks, and regular software updates are crucial for identifying and addressing potential threats. Organizationally, ongoing training and awareness programs are key to reducing the risks posed by human error. Additionally, the integration of physical, technical, and organizational defenses is necessary to create a resilient and adaptive security posture. The lessons learned from this attack extend beyond the specific context of Iran's nuclear program, serving as a vital reminder for industries worldwide that depend on interconnected systems.

To conclude, Stuxnet slowed down Iran's nuclear program, but at the same time, it reshaped global perspectives on the intersection of cybersecurity and industrial operations, helping to define the concept of hybrid threats. Therefore, it's essential to emphasize that the industries must prioritize resilience and adaptability, in order to face the increasing number of cyber threats.

List of Figures

1.1 Geopolitical Timeline 3

3.1 Key Milestones Timeline 6

4.1 Fault Tree 9
4.2 Stuxnet Version 1.0 fault tree branch 17
4.3 Stuxnet Version 2.0 fault tree branch 18
4.4 Stuxnet Version 2.1 fault tree branch 19

5.1 Behavioral Analysis Schema 21

Bibliography

[1] Irans nuclear program: Tehrans compliance with international obligations. 2012. URL https://api.semanticscholar.org/CorpusID:197420323.

[2] D. Albright and C. Hinderstein. The iranian gas centrifuge uranium enrichment plant at natanz. 2003. URL https://www.isis-online.org/publications/iran/natanz03_02.html?utm_source=chatgpt.com.

[3] W. N. Association. Uranium enrichment. 2024. URL https://world-nuclear.org/information-library/country-profiles/countries-g-n/iran.

[4] CCDCOE. Stuxnet facts report: A technical and strategic analysis. 2012. URL https://ccdcoe.org/uploads/2018/10/Falco2012_StuxnetFactsReport.pdf.

[5] R. Langner. To kill a centrifuge a technical analysis of what stuxnet's creators tried to achieve. 2013. URL https://api.semanticscholar.org/CorpusID:14733319.

[6] M. M. Llinàs. Hybrid attacks on critical infrastructure. 2022. URL https://www.cidob.org/en/publications/hybrid-attacks-critical-infrastructure.

[7] U. Nations. Treaty on the non-proliferation of nuclear weapons. 1 July 1968. URL https://treaties.unoda.org/t/npt/participants.

[8] U. Nations. Agreement for co-operation concerning civil uses of atomic energy. 5 March 1957. URL https://treaties.un.org/Pages/showDetails.aspx?objid=080000028013d0ba.

[9] L. O. M. Nicolas Falliere and E. Chien. W32.stuxnet dossier. *Symantec*, February 2011.

[10] NTI. Natanz enrichment complex. 2023. URL https://www.nti.org/education-center/facilities/natanz-enrichment-complex/.